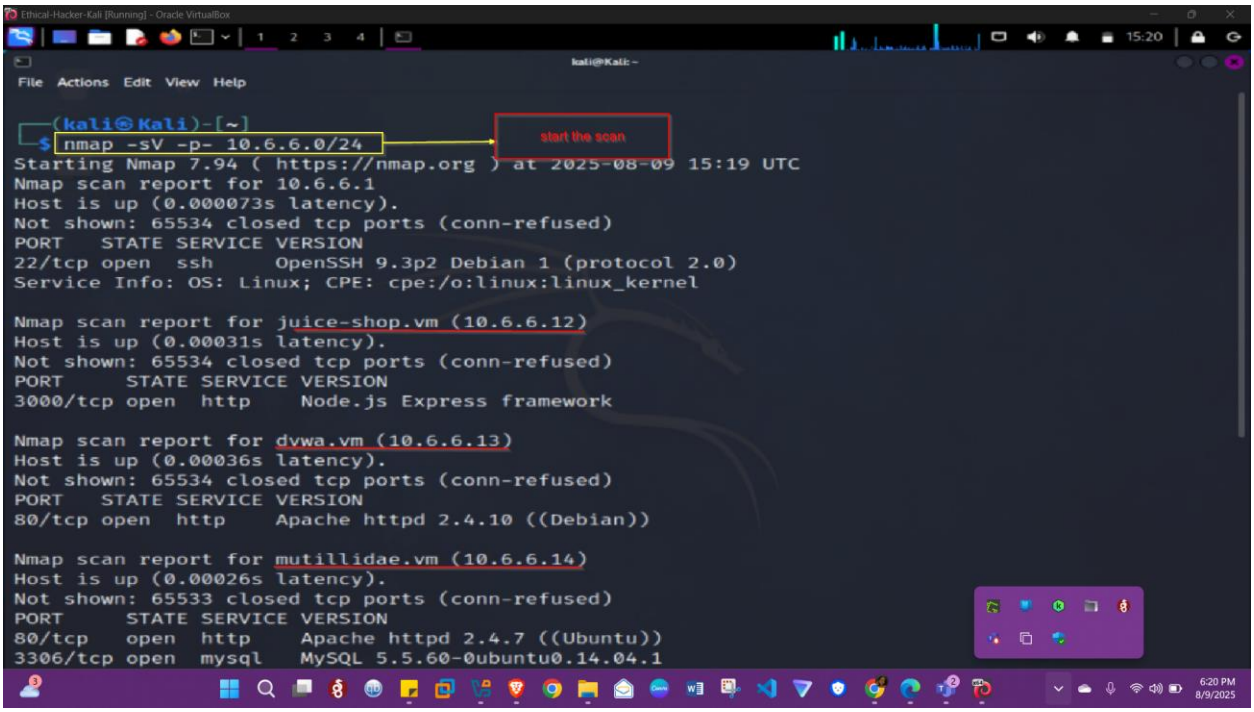
Operation ShadowFlag

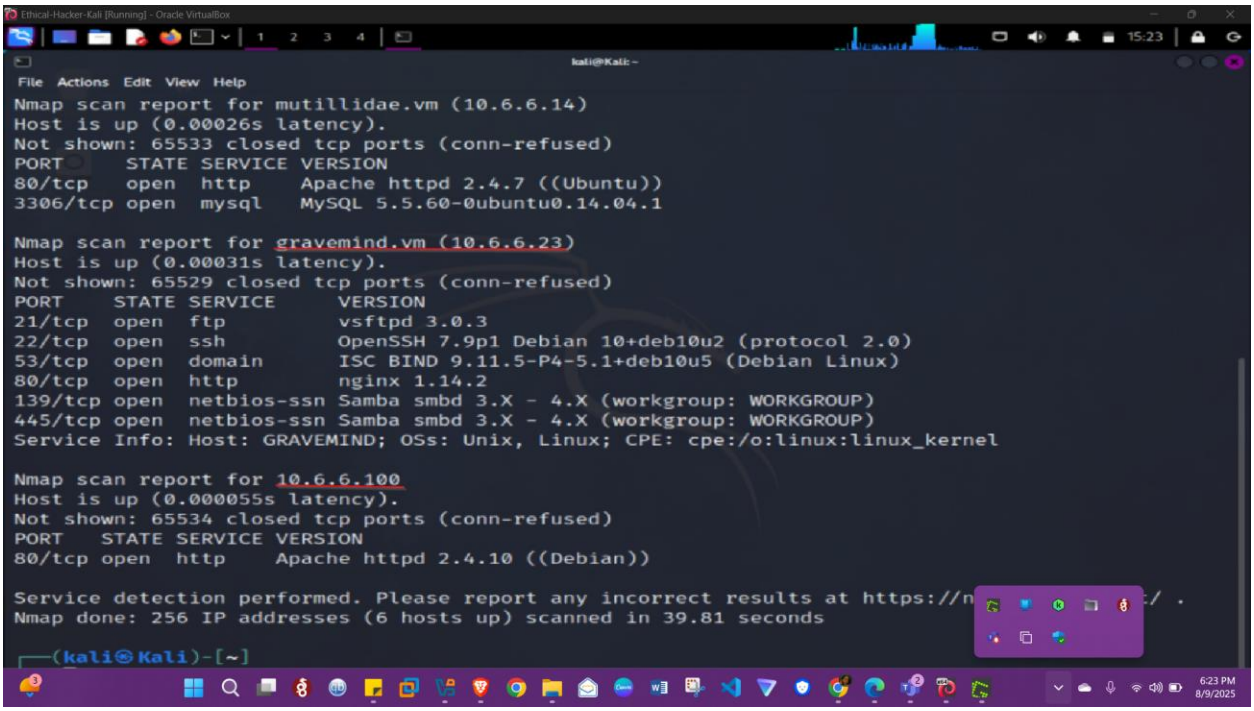
Part A: Enumeration and Identification

1. Using Nmap, find the different hosts running on the subnet and describe each of them: 10.6.6.0/24. **(5 Marks)**

Answer: Juice-shop.vm 10.6.6.12, dvwa.vm 10.6.6.12, mutillidae.vm 10.6.6.14, gravemind.vm 10.6.6.23

Using Nmap, find the different hosts running on the subnet





Nmap – to launch the tool

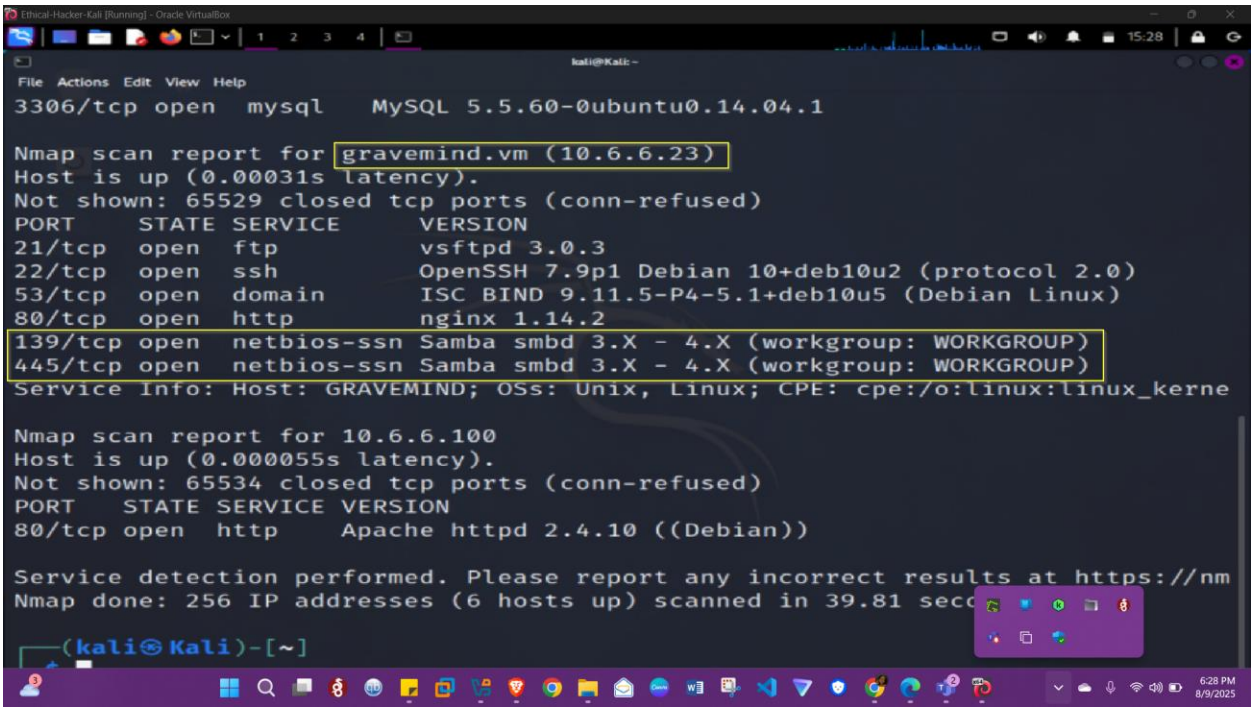
-sV to initiate a version scan

-p- to scan all ports

2. Which of these host IPs shows open SMB ports?

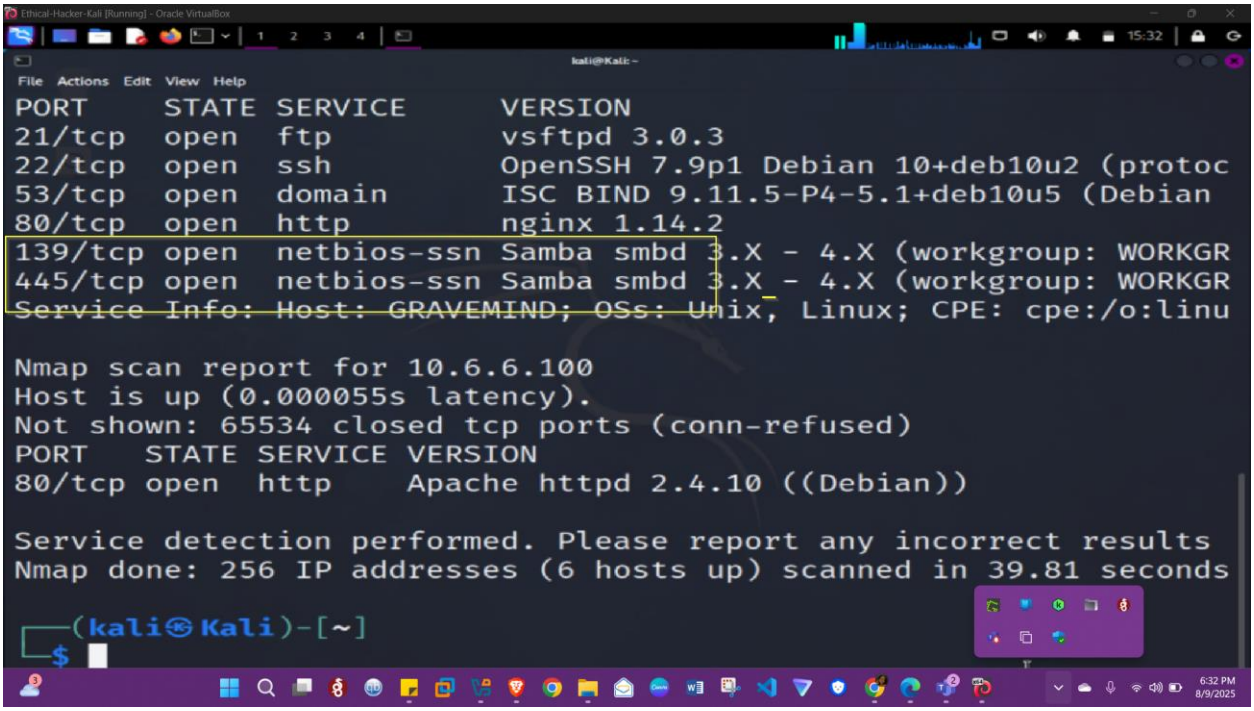
Answer: 10.6.6.23

Gravemind. Vm 10.6.6.23 has SMB ports 139/tcp and 445/tcp open



3. What specific open ports indicate that a device is running SMB services?

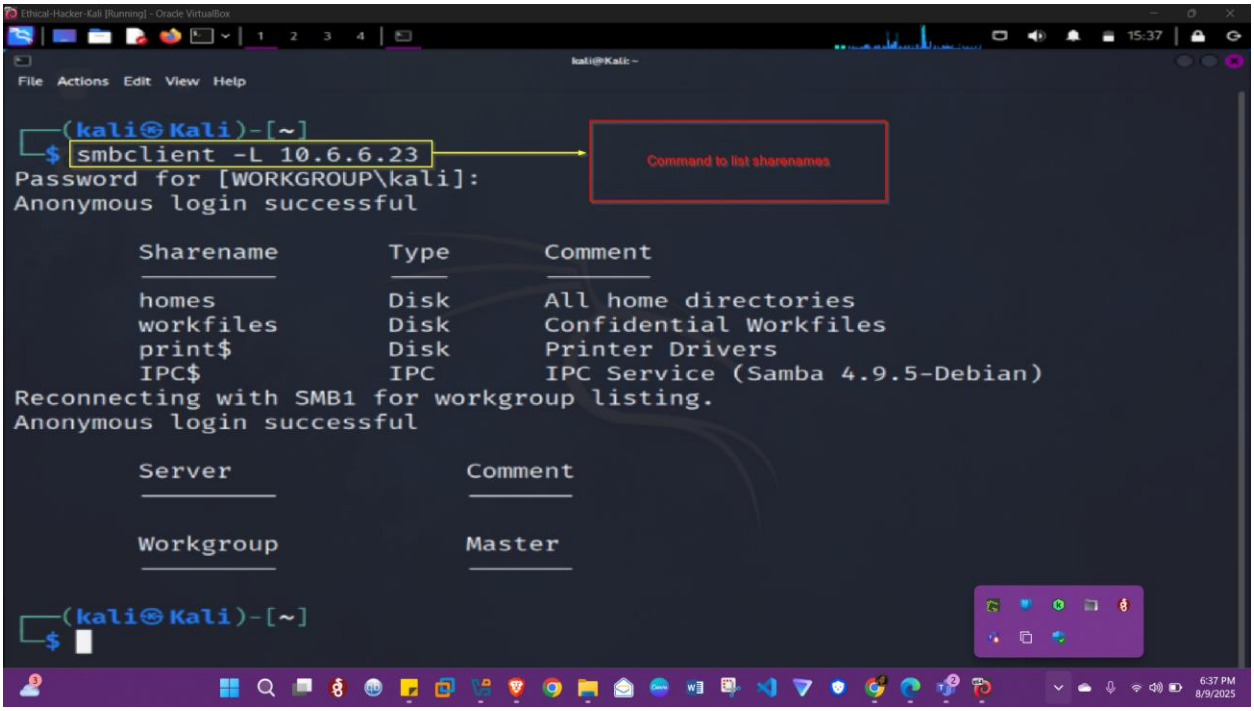
Answer: Tcp ports 445 and 139 are used for SMB server shares.



4. Use an enumeration tool to discover available SMB shares on the host identified in (2).
   a. List all the discovered share names

Answer: homes, workfiles, print$, IPC$

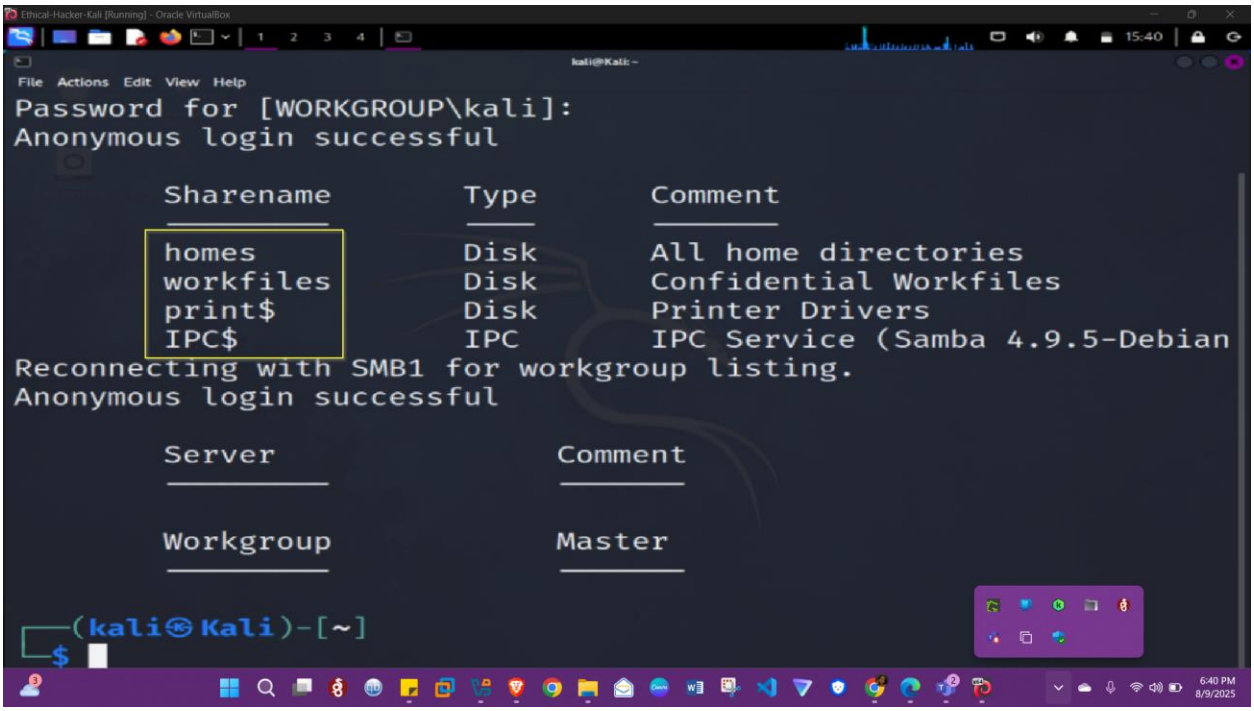
discover available SMB shares on the host



b. Which of these shares are accessible without credentials (as an anonymous user)
Answer: workfiles, print$ and IPC$

Part B: **Access and Exploration**

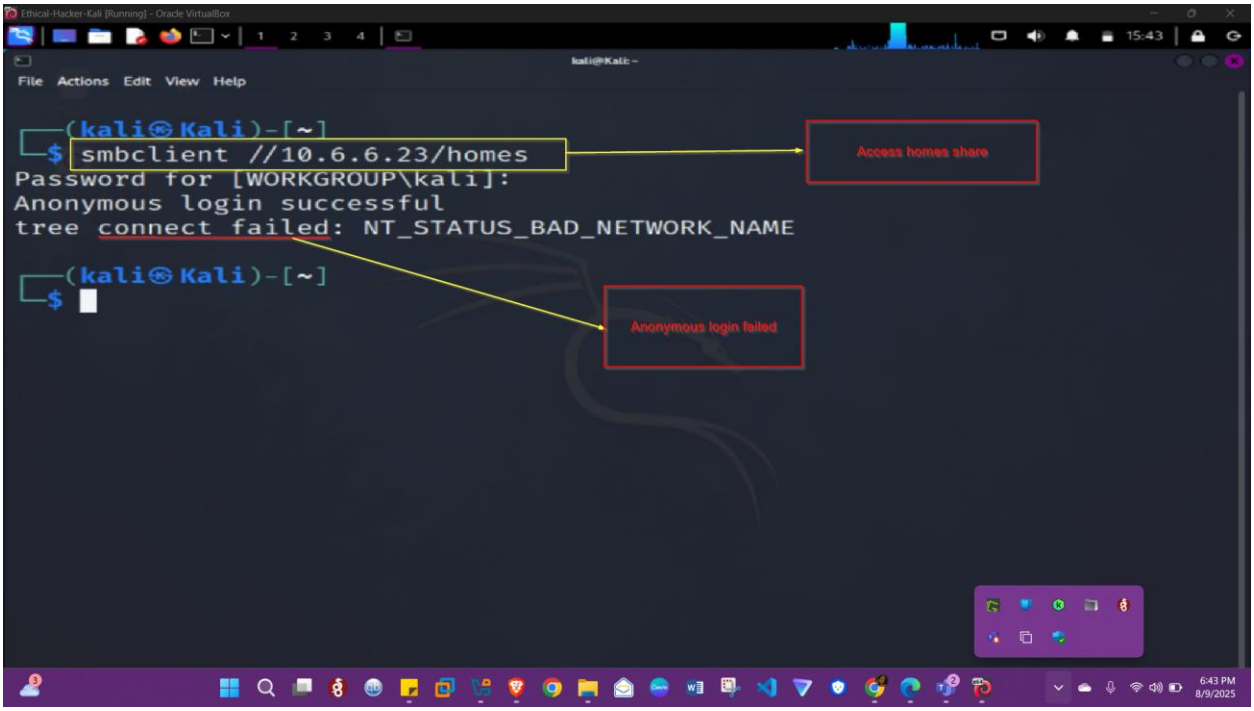
Share found with anonymous login are:



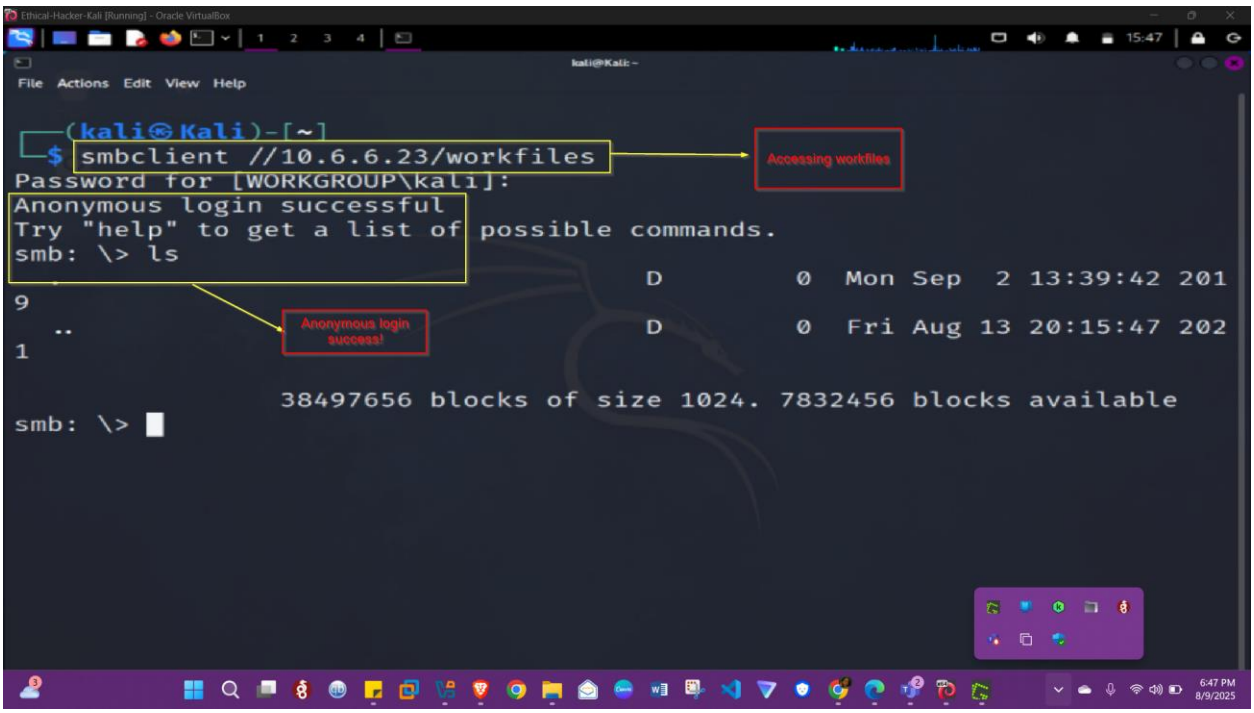
5. Describe how you would use SMBCLIENT or an equivalent tool to connect anonymously to one of the discovered shares. Demonstrate this and provide the command used.

Accessing the shares using anonymous login:

Homes share

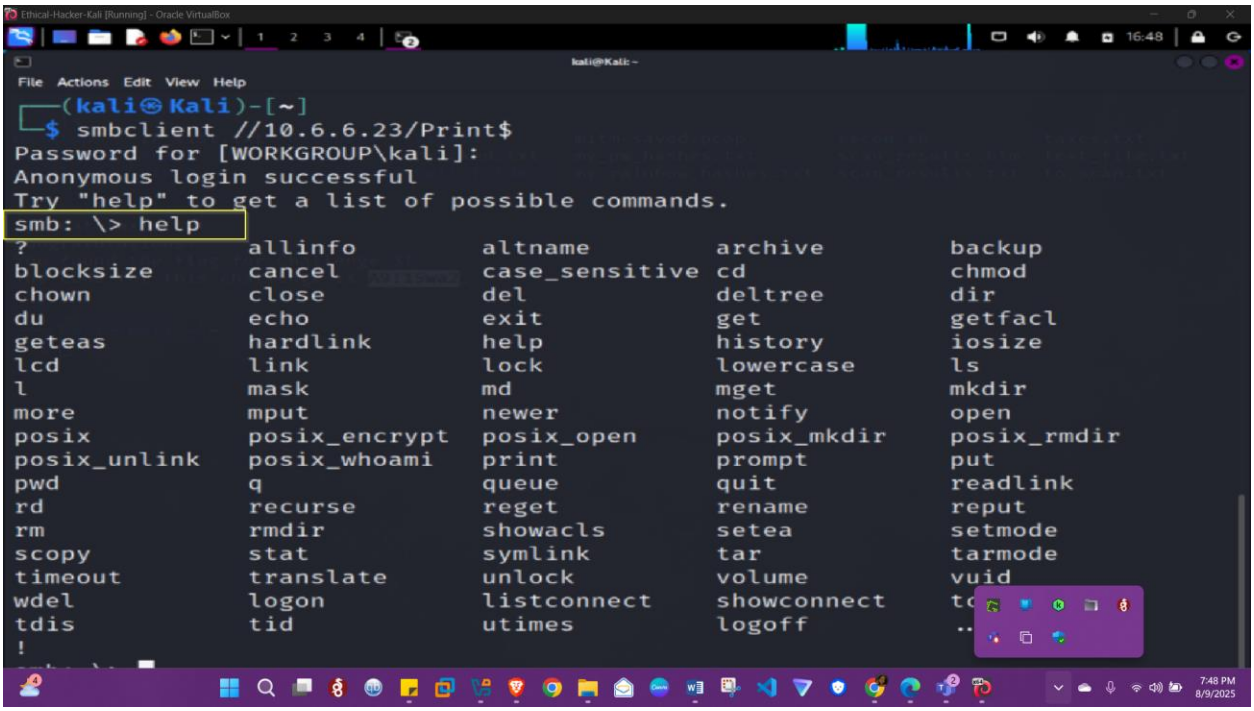


Workfiles

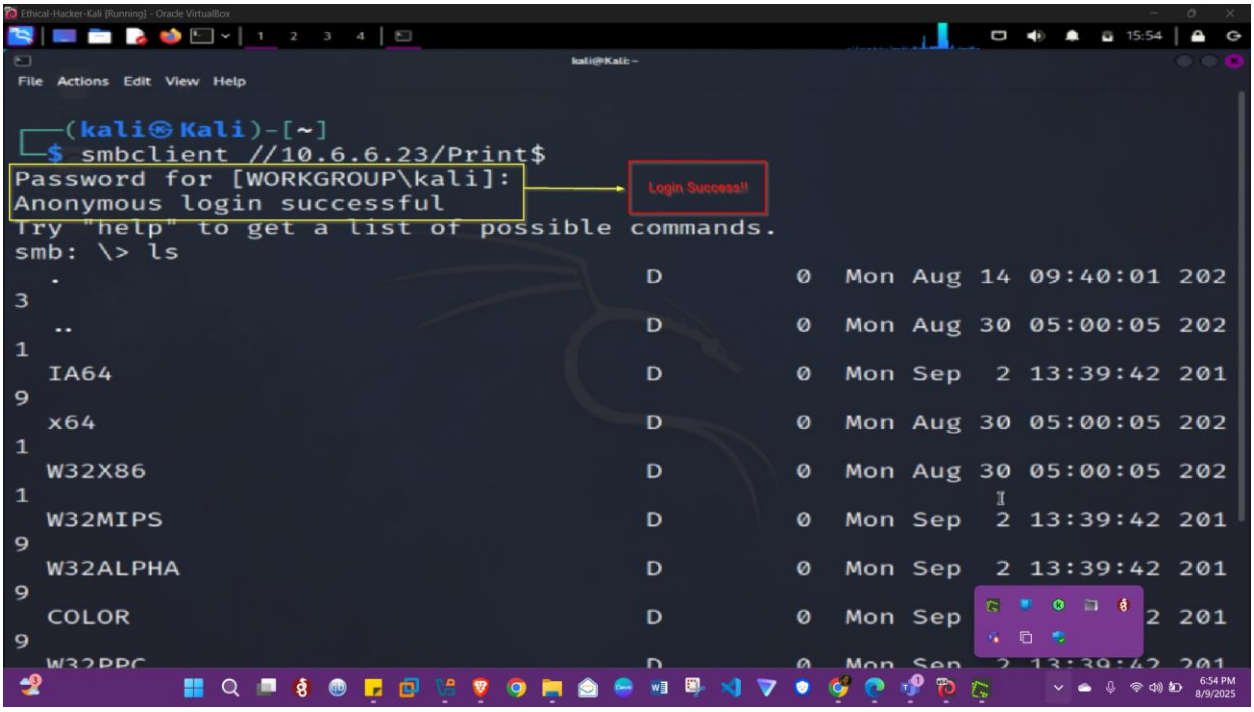


No files found here

6. After connecting to a share, how do you navigate the directory structure to find files and subfolders? Include at least three CLI commands and give screenshots of each used
   Use the help command to identify command to use

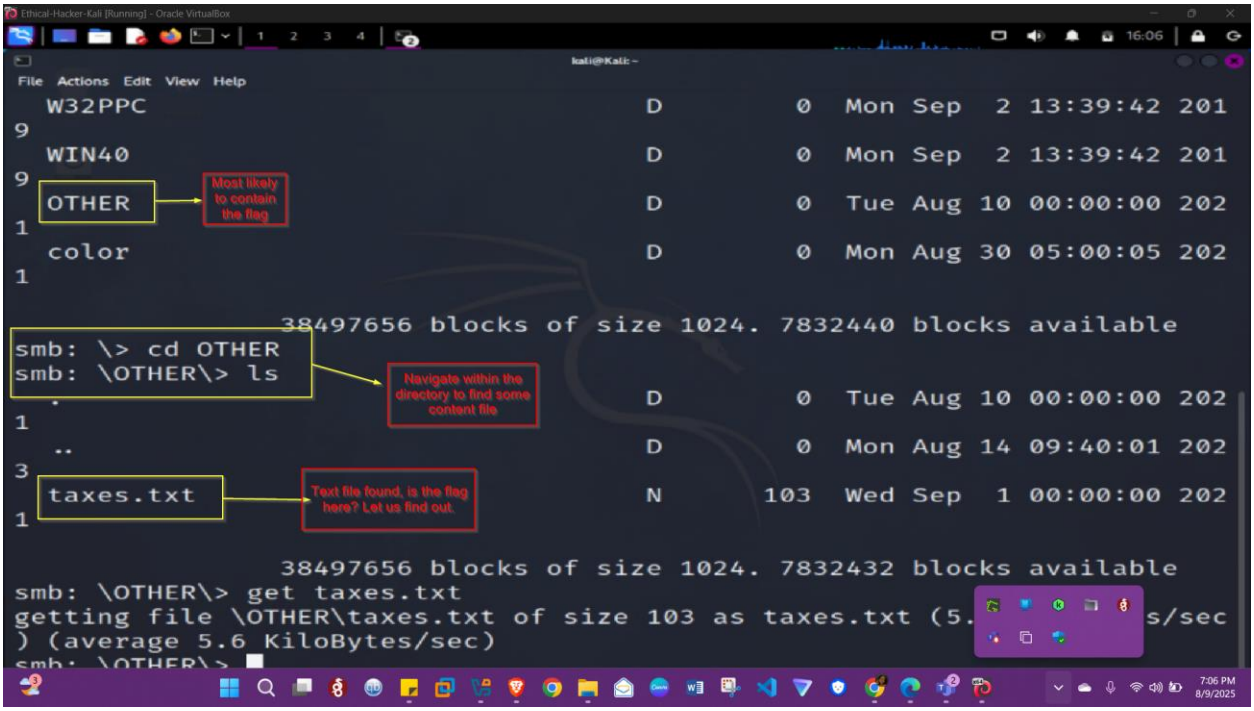


Use ls to list directory files



The Directory OTHER Looks interesting. Navigate to it using cd command

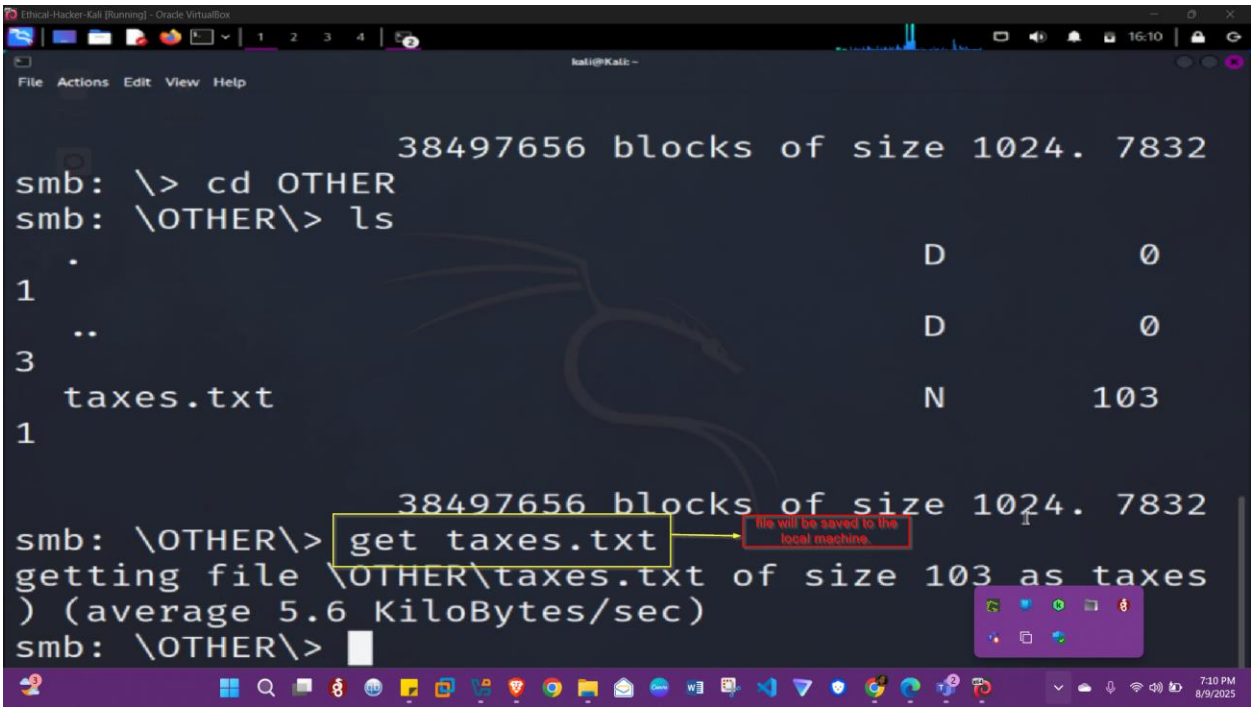
7. On which share is an interesting **File** with a Flag located?
   Answer: print$ share



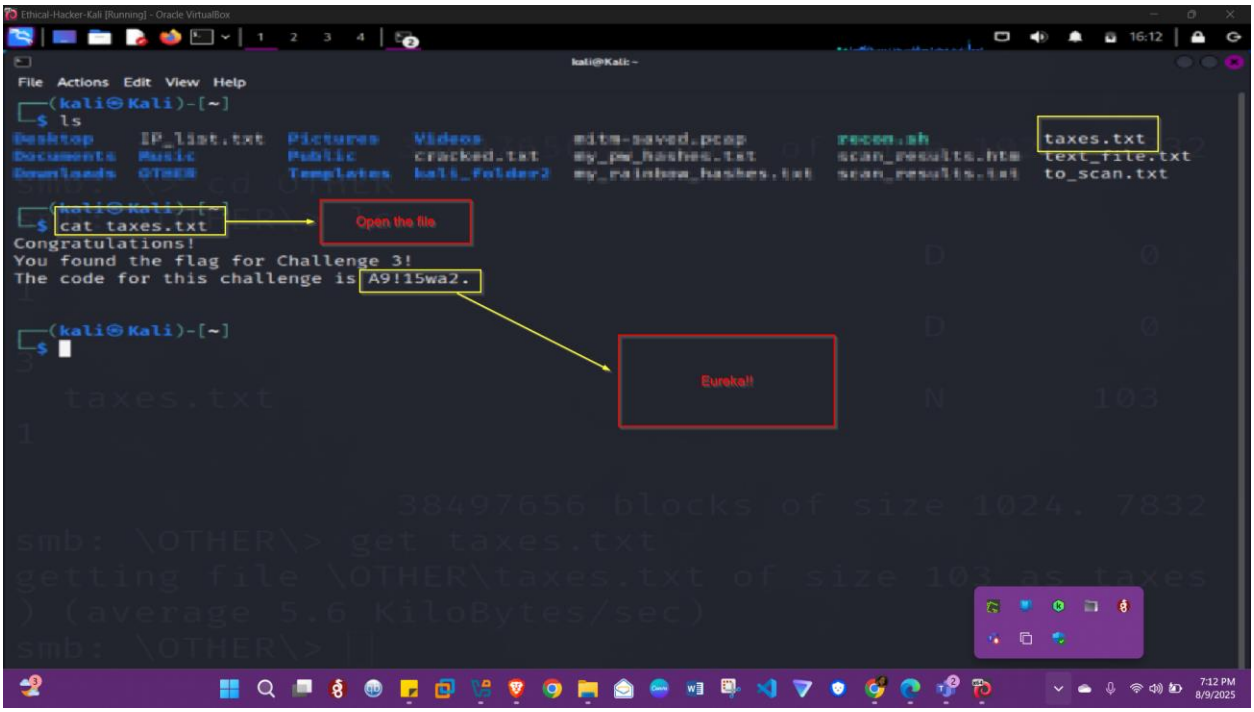
8. What is the **exact file name** containing the Flag?
   Answer: taxes.txt

9. Retrieve and inspect the file with the Flag

   a. How did you download the file locally from the share? Explain your process and provide screenshots. Provide the commands.
      - Use the get command to exfiltrate the file to the local system



b. What method did you use to read or open the file contents? Show the screen contents
   - Use cat to view contents of taxes.txt



10. What is the code for the Flag found in the file

Answer: Code: A9!15wa2

Part C: **Analysis and Reporting**

1. **Three** security risks this setup introduces

- Sensitive internal files can be accessed by anyone on the network and or even externally if the server is exposed. This could lead to intellectual property theft or leakage of personally identifiable information (PII).
- Without authentication, attackers can upload malicious files to the share. Other users accessing the share could execute them, spreading malware across the network.
- Publicly accessible shares, like this one, may contain configuration files, scripts, or password dumps that attackers can use to pivot and gain higher privileges in the network.

2. Suggest **three** mitigations.
   - Enforce Authentication & Access Control
   - Taking up network segmentation and the use of firewalls
   - Track file access, creation, and deletion on shares with an IDS or IPS

3. **two tools** other than NMAP and SMBCLIENT that are commonly used for SMB enumeration, and distinguish each by its strengths
   a. Enum4linux
   - Its **strength** is that it's made just for poking around Windows and Samba (SMB/NetBIOS systems), and it bundles all give queries questions into **one** quick sweep instead of you doing them one at a time.

   b. Zenmap
   - Its strength is that it uses a GUI